PROYECTO RENIEC - BID
Mejoramiento del acceso a los servicios de registros civiles e identificación de calidad a nivel nacional

ESTÁNDAR DE AUTENTICACIÓN Y AUTORIZACIÓN

Mejoramiento de Acceso a los Servicios de Registros Civiles e Identificación de Calidad a Nivel Nacional (Contrato de Préstamo BID № 4297/OC-PE)

Componente 3: Incorporación de tecnologías para la prestación de los servicios

RENIEC
REGISTRO NACIONAL DE IDENTIFICACIÓN Y ESTADO CIVIL

Elaborado por:

Ing. Jarol Adolfo Bastidas Orihuela
Especialista en Arquitectura de Soluciones Senior

Ing. Gustavo Alfonso Montenegro Marcial
Especialista en Arquitectura de Soluciones Junior

Historial de modificaciones del Estándar de Autenticación y Autorización

Versión	Fecha	Modificaciones	Preparado/Revisado por
1.0	30/04/2024	Versión inicial	Jarol Adolfo Bastidas Orihuela Gustavo Alfonso Montenegro Marcial
1.1	12/08/2025	Versión actualizada	Jarol Adolfo Bastidas Orihuela

FIRMA DIGITAL

Firmado digitalmente por: BASTIDAS ORIHUELA JAROL ADOLFO FIR 40561133 hard
Motivo: Soy el autor del documento
Fecha: 15/09/2025 09:37:19-0500

MIGUEL ÁNGEL MARTÍNEZ LA ROSA
Jefe de la Unidad de Ingeniería de Software
REGISTRO NACIONAL DE IDENTIFICACION Y ESTADO CIVIL

Firmado digitalmente por: MARTINEZ LA ROSA Miguel Angel FAU 20295613620 soft
Motivo: En señal de conformidad
Fecha: 15/09/2025 14:23:10-0500

1. OBJETIVO

Establecer los protocolos estándar de autenticación y autorización que deberán utilizar las aplicaciones que soportan los procesos misionales del RENIEC a fin de garantizar el acceso autorizado a los recursos.

2. ÁREA RESPONSABLE

Oficina de Tecnologías de la Información

i. **Unidad de Ingeniería de Software:** Es el responsable de la definición del estándar de autenticación y autorización, de mantenerla actualizada y de verificar el cumplimiento del estándar.
ii. **Líder del Equipo de Desarrollo:** Es el encargado de solicitar el soporte para cumplir con los controles sobre autenticación y autorización que se definen en el presente documento.

3. ALCANCE

El presente estándar aplica para su uso en la implementación del Sistema Integrado de Identificación y Registro Civil (SIIRC) y constituye además una guía de buenas prácticas para el desarrollo y mantenimiento de los sistemas de información a cargo de la Unidad de Ingeniería de Software (UIS).

4. REQUISITOS

4.1 Tipos de aplicaciones

Cada tipo de aplicación puede manejar un estándar de autenticación distinto, por lo cual es importante definir los tipos de aplicaciones que pueden desarrollarse, sin importar el lenguaje o la plataforma.

4.1.1 Aplicaciones autenticadas:

Son aquellas aplicaciones donde un usuario requiere autenticarse de manera interactiva a fin de comprobar quien dice ser y de esa forma obtener acceso a los recursos solicitados.

4.1.2 Aplicaciones anónimas:

Son aquellas aplicaciones donde no se requiere que un usuario se autentique de manera interactiva y que, por el contrario, está destinado al uso de usuarios anónimos. Este tipo incluye a aplicaciones públicas, aplicaciones batch o APIs Web que llaman a otra API WEB.

4.2 Estándares de autenticación y autorización

4.2.1 Aplicaciones autenticadas de usuarios internos del RENIEC

a) Autenticación

Toda aplicación del RENIEC cuyos usuarios finales sean servidores públicos deberán delegar la autenticación a la Plataforma de Gestión de Identidades de servidores públicos del RENIEC (Identity Server). Este componente es compatible con protocolos estándares como OpenID Connect (OIDC), OAuth 2.0 y SAML 2.0.

Los mecanismos de autenticación que se deben implementar dependen del tipo de aplicación que se desarrolle:

- Para aplicaciones móviles y nativas: OIDC + OAuth 2.0 Authorization Code
- Para aplicaciones web tradicionales: OIDC + OAuth 2.0 Authorization Code
- Para aplicaciones Single Page (SPA): OIDC + OAuth 2.0 Authorization Code Flow with PKCE

Como resultado de una autenticación exitosa del servidor público, este obtendrá un **ID Token** representado en formato JWT (JSON Web Token). El ID Token es un token de seguridad que contiene información de la identidad del usuario autenticado, por ende, será necesario que la aplicación lo envíe en cada solicitud de un recurso web.

b) Autorización

Además de un inicio de sesión (autenticación), una aplicación podría tener la necesidad de acceder a un recurso web, tal como una API REST. En ese caso, la aplicación deberá utilizar el estándar **OAuth 2.0 Client Credentials** para obtener un acceso token del API Management y en combinación con el ID Token, obtener el acceso al recurso solicitado.

4.2.2 Aplicaciones autenticadas de usuarios externos del RENIEC

a) Autenticación

Toda aplicación del RENIEC cuyos usuarios finales sean usuarios externos deberán delegar la autenticación a la Plataforma de Gestión de Identidades de usuarios externos del RENIEC (Identity Server). Este componente es compatible con protocolos estándares como OpenID Connect (OIDC), OAuth 2.0 y SAML 2.0.

El acceso de usuarios externos requiere autenticación multifactor (MFA). El factor primario y recomendado será MFA resistente al phishing, priorizando:
Passkeys (FIDO2/WebAuthn): seguridad basada en criptografía de clave pública.

Los mecanismos de autenticación que se deben implementar dependen del tipo de aplicación que se desarrolle:

- Para aplicaciones móviles y nativas: OIDC + OAuth 2.0 Authorization Code
- Para aplicaciones web tradicionales: OIDC + OAuth 2.0 Authorization Code
- Para aplicaciones Single Page (SPA): OIDC + OAuth 2.0 Authorization Code Flow with PKCE

Como resultado de una autenticación exitosa del usuario externo, este obtendrá un **ID Token** representado en formato JWT (JSON Web Token). El ID Token es un token de seguridad que contiene información de la identidad del usuario autenticado, por ende, será necesario que la aplicación lo envíe en cada solicitud de un recurso web.

b) Autorización

Además de un inicio de sesión (autenticación), una aplicación podría tener la necesidad de acceder a un recurso web, tal como una API REST. En ese caso, la aplicación deberá utilizar el estándar **OAuth 2.0 Client Credentials** para obtener un acceso token del API Management y en combinación con el ID Token, obtener el acceso al recurso solicitado.

4.2.3 Aplicaciones anónimas o batch

a) Autenticación

Toda aplicación anónima que no requiera autenticar a ningún usuario, pero que sí requiera acceder a un recurso web, tal como un API REST, deberá utilizar alguno de los siguientes mecanismos de autenticación, en el orden establecido:

- OAuth 2.0 Client Credentials
- Client Certificates
- API Key + Filtro por IP (*)
- Basic Authentication (**)

(*) Este mecanismo de autenticación está deprecado y solo puede ser utilizado a nivel de API Management. Su uso queda restringido únicamente a escenarios específicos donde el consumidor no soporte ninguno de los métodos de autenticación precedentes.
(**) Este mecanismo de autenticación está deprecado. Su uso queda restringido únicamente a escenarios específicos donde el consumidor no soporte ninguno de los métodos de autenticación precedentes.

b) Autorización

Al igual que los otros tipos de aplicación, el estándar para acceder a un recurso web, tal como un API REST, desde aplicaciones anónimas es **OAuth 2.0 Client Credentials**. Una vez autenticada contra el API Management, la aplicación obtendrá un access token la cual usará para obtener acceso al recurso solicitado.